AIEP de la Universidad Andrés Bello

De la vulnerabilidad al plan de mitigación

Objetivo

Relacionar los hallazgos de vulnerabilidades con los **controles de ISO 27001**, elaborando un plan de acción priorizado según impacto y probabilidad.

Activación

Una empresa detecta 3 vulnerabilidades en su red: puerto 21 FTP abierto sin cifrado, uso de SMBv1, y contraseñas débiles en SSH.

¿Cuál vulnerabilidad corregirías primero y por qué?

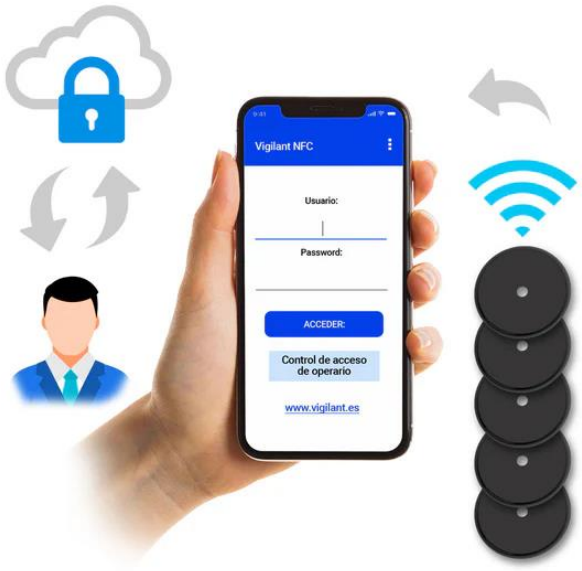
ISO 27001

- **A.9**: Control de accesos.
- **A.12**: Seguridad en operaciones.
- **A.13**: Seguridad en comunicaciones.
- **A.17**: Continuidad del negocio.

A.9: Control de Accesos

Objetivo: Asegurar que solo usuarios autorizados accedan a los sistemas y datos.

- **Políticas de contraseñas** (robustas, no repetidas).
- **Gestión de roles y permisos** (principio de mínimo privilegio).
- **Autenticación multifactor (2FA)**.
- **Revocar accesos de ex-empleados**.



Ejemplo aplicado: evitar accesos por fuerza bruta detectados con Hydra.

A.12: Seguridad en Operaciones

Objetivo: Mantener la seguridad en los procesos diarios de TI.

- **Actualización y parcheo regular** de sistemas.
- **Monitoreo de logs y alertas**.
- **Hardening de servidores** (eliminar servicios innecesarios).
- **Gestión de copias de seguridad operativas**.

Ejemplo aplicado: cierre de servicios inseguros detectados con Nmap.

A.13: Seguridad en Comunicaciones

Objetivo: Proteger la información en tránsito entre sistemas.

- **Uso de cifrado TLS/SSL** en servicios web.
- **VPNs seguras** para conexiones remotas.
- **Correo electrónico cifrado** y políticas anti-phishing.
- **Bloquear protocolos inseguros (FTP, Telnet, SMBv1)**.

Ejemplo aplicado: vulnerabilidad de SMBv1 detectada con Enum4linux.

A.17: Continuidad del Negocio

Objetivo: Garantizar que la organización siga operando durante incidentes de seguridad.

- **Planes de continuidad y recuperación (**Business Continuity Plan **BCP/** Disaster Recovery Plan **DRP)**.
- **Backups periódicos y pruebas de restauración**.
- **Redundancia en infraestructura crítica**.
- **Simulacros de ciberincidentes**.

Ejemplo aplicado: protección contra ataques DoS/Impacto vistos con Ettercap

Análisis y Priorización

- Cada grupo recibe una **lista de vulnerabilidades comunes** (ej. servicios desactualizados, puertos inseguros, contraseñas débiles, falta de backups).
- Usan una **matriz de riesgos simple** (Probabilidad vs Impacto → Bajo/Medio/Alto).
- El objetivo es **priorizar los riesgos** y proponer acciones de mitigación.